
Informe de Pentesting

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Licenciatura en Sistemas de Información — Facultad de Informática y Diseño

Docente: Ing. Rodrigo Atilio Elgueta

Estudiante: Lucrecia Concatti

Username TryHackMe: lucre54

Ciclo Académico Vigente

Contents

1	Datos generales	2
2	Pre-pentesting	2
3	Durante: Hallazgos por fase	3
4	Resumen ejecutivo de hallazgos	7
5	Post-pentesting: Recomendaciones	8
6	Protocolo de Contingencia	8
7	Anexos	9

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Lucrecia Concatti
DNI	45.256.542
Username TryHackMe	lucre54
Email institucional	concattilucrecia@uch.edu.ar
Sala de elección (Nivel 2)	RootMe
Branch en GitHub	concatti-lucrecia
Fecha de inicio	02/10/2026
Fecha de cierre	05/10/2026

2. Pre-pentesting

Alcance del trabajo

El alcance de esta intervención comprende únicamente los entornos de laboratorio provistos por la plataforma TryHackMe, correspondientes a las siguientes salas:

- **Pentesting Fundamentals** (núcleo obligatorio): entorno simulado de la empresa ficticia ACME.
- **Basic Pentesting** (núcleo obligatorio): máquina Linux con servicios SSH, HTTP y Samba (*Web App Test*).
- **RootMe** (sala de elección, Nivel 2): máquina Linux con servicio web vulnerable (*HackIT - Home*).

Quedan expresamente **excluidos** del alcance: cualquier sistema fuera de las máquinas asignadas por TryHackMe para cada sala, la infraestructura real de INSECUR S.A. (inexistente, utilizada solo como marco narrativo), y cualquier sistema de terceros accesible desde la red de laboratorio.

Reglas de Enfrentamiento (ROE)

Horarios: las pruebas se realizaron exclusivamente dentro de las sesiones de laboratorio habilitadas por la cátedra, con la máquina virtual (VPN de TryHackMe) activa y el tiempo de vida de cada *lab machine* controlado por la propia plataforma.

Técnicas prohibidas: no se realizaron ataques de denegación de servicio (DoS) sostenidos, fuerza bruta indiscriminada fuera de lo estrictamente necesario para la sala, ni intentos de pivoteo hacia redes fuera del rango asignado por TryHackMe.

Límites de tráfico: los escaneos de puertos se realizaron con `nmap` en modo moderado (`-T4`), evitando saturar el enlace VPN; la enumeración de directorios web se acotó a diccionarios estándar (`dirb/common.txt`).

Notificación ante incidentes: cualquier comportamiento anómalo del laboratorio (caída de la VPN, máquina inaccesible, reinicio inesperado) se gestionó reconectando según las herramientas provistas por TryHackMe, sin requerir escalado al docente en esta instancia.

Autorización

Declaro que las actividades descritas en este informe se realizaron únicamente sobre los entornos de laboratorio provistos por TryHackMe, bajo autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH), en el marco de la Actividad A08. Ninguna técnica aquí documentada fue aplicada contra sistemas reales o de terceros sin autorización.

Metodología utilizada

Se siguió un enfoque alineado a **PTES (Penetration Testing Execution Standard)**, adaptado a las cuatro fases propuestas por la guía de cátedra: *Reconocimiento*, *Escaneo*, *Explotación* y *Post-explotación*. Se eligió PTES por ser un estándar ampliamente adoptado en la industria, con un flujo de trabajo claro y iterativo que facilita la trazabilidad de cada hallazgo desde su detección hasta su remediación, y porque se corresponde directamente con la estructura de evidencias solicitada por la cátedra (carpetas `reconocimiento/`, `escaneo/`, `explotacion/`, `post/`).

3. Durante: Hallazgos por fase

H-01 — Clave SSH privada con permisos de lectura pública

Campo	Valor
ID del hallazgo	H-01
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Durante la enumeración local con LinPEAS en la sala <i>Basic Pentesting</i> , se detectó que la clave privada SSH del usuario <code>kay (/home/kay/.ssh/id_rsa)</code> tenía permisos <code>-rw-r--r--</code> , es decir, legible por cualquier usuario del sistema. La clave estaba protegida por passphrase, pero ésta pudo ser obtenida mediante ataque de diccionario fuera de línea con <code>ssh2john</code> y <code>john</code> , permitiendo autenticarse como <code>kay</code> (miembro del grupo <code>sudo</code>).
Componente afectado	Servicio SSH (OpenSSH 8.2p1) — archivo <code>/home/kay/.ssh/id_rsa</code>
Categoría (OWASP / CWE)	CWE-522: Insufficiently Protected Credentials
CVE (si aplica)	No aplica (error de configuración, no vulnerabilidad de software)

CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	<code>evidencias/post/22_postexplotacion.H-03.png</code> (clave expuesta), <code>evidencias/post/24_postexplotacion.H-05.png</code> (crackeo con john)
Herramienta utilizada	LinPEAS, <code>ssh2john</code> , <code>john</code> (<code>rockyou.txt</code>)
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Restringir permisos de la clave privada a 600 (<code>chmod 600 ~/.ssh/id_rsa</code>); rotar la clave comprometida; establecer una passphrase robusta que no figure en diccionarios conocidos; auditar periódicamente permisos de archivos sensibles en <code>/home</code> .
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-02 — Contraseña de sudo almacenada en archivo de backup legible

Campo	Valor
ID del hallazgo	H-02
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Una vez autenticada como <code>kay</code> , se encontró en su directorio personal un archivo <code>pass.bak</code> legible que contenía la contraseña de <code>sudo</code> en texto plano. Dado que <code>kay</code> pertenece al grupo <code>sudo</code> con permisos (<code>ALL : ALL</code>) <code>ALL</code> , esta credencial permitió la escalada de privilegios completa hasta el usuario <code>root</code> .
Componente afectado	Archivo <code>/home/kay/pass.bak</code>
Categoría (OWASP / CWE)	CWE-312: Cleartext Storage of Sensitive Information
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico

Evidencia (captura / comando)	<code>evidencias/post/27_postexplotacion_H-08.png</code> , <code>evidencias/post/29_postexplotacion_H-10.png</code> (escalada a root)
Herramienta utilizada	Acceso de shell como <code>kay</code> , <code>cat</code> , <code>sudo -l</code> , <code>sudo su</code>
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Eliminar de forma inmediata todo archivo de backup que contenga credenciales en texto plano; adoptar un gestor de secretos (por ejemplo, Vault o SOPS) para el manejo de contraseñas administrativas; nunca almacenar contraseñas fuera de mecanismos cifrados dedicados.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-03 — Carga de archivos sin restricción efectiva de tipo (bypass de filtro de extensión)

Campo	Valor
ID del hallazgo	H-03
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	En la sala <i>RootMe</i> , la enumeración web con <code>gobuster</code> reveló un directorio <code>/panel/</code> sin autenticación, que exponía un formulario de carga de archivos. Un primer intento de subir una <i>web shell</i> en PHP (<code>shell.php</code>) fue bloqueado por un filtro de tipo <i>blacklist</i> ("PHP não é permitido!"). El filtro, sin embargo, sólo validaba la extensión literal <code>.php</code> : al renombrar el mismo archivo a <code>shell.phtml</code> (extensión que Apache también interpreta como PHP ejecutable), la carga fue aceptada, permitiendo obtener ejecución remota de código (RCE) y una reverse shell como el usuario <code>www-data</code> .
Componente afectado	Formulario de carga en <code>/panel/</code> — Apache httpd 2.4.41 (Ubuntu)
Categoría (OWASP / CWE)	CWE-434: Unrestricted Upload of File with Dangerous Type (OWASP A04:2021 — Insecure Design)
CVE (si aplica)	No aplica (falla de diseño específica de la aplicación)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico

Evidencia (captura / comando)	<code>evidencias/explotacion/37_explotacion_RM-05_filtro_extension_php.png</code> (bloqueo inicial), <code>evidencias/explotacion/39_explotacion_RM-07_bypass_ext</code> (bypass exitoso), <code>evidencias/explotacion/40_explotacion_RM-08_reverse_sh</code> (shell obtenida)
Herramienta utilizada	<code>gobuster</code> , navegador web (carga manual), <code>php-reverse-shell.php</code> (webshells de Kali), <code>netcat</code> (<code>nc -lvnp</code>)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Implementar una lista blanca (<i>whitelist</i>) estricta de extensiones permitidas en lugar de una lista negra; validar el tipo MIME real del archivo (no solo su extensión) inspeccionando el contenido (<i>magic bytes</i>); almacenar los archivos subidos fuera del <i>document root</i> o con permisos de no-ejecución; exigir autenticación para acceder a <code>/panel/</code> .
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-04 — Binario con bit SUID mal configurado (python2.7)

Campo	Valor
ID del hallazgo	H-04
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Con acceso de shell como <code>www-data</code> en la sala <i>RootMe</i> , la búsqueda de binarios con bit SUID (<code>find / -perm -4000</code>) reveló que <code>/usr/bin/python2.7</code> tenía dicho bit activado, una configuración anómala para un intérprete de propósito general. Esto permitió ejecutar <code>python2.7 -c 'import os; os.setuid(0); os.system("/bin/bash")'</code> para obtener una shell con privilegios de <code>root</code> de forma inmediata, sin necesidad de explotar ninguna vulnerabilidad de software adicional.
Componente afectado	Binario <code>/usr/bin/python2.7</code>
Categoría (OWASP / CWE)	CWE-269: Improper Privilege Management (OWASP A05:2021 — Security Misconfiguration)
CVE (si aplica)	No aplica (error de configuración del sistema)

CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	<code>evidencias/post/42_postexplotacion_RM-10_suid_python27_encontrado.png</code> <code>evidencias/post/43_postexplotacion_RM-11_escalada_suid_python_root.png</code>
Herramienta utilizada	<code>find -perm -4000</code> , intérprete <code>python2.7</code> (explotación manual)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Eliminar el bit SUID de intérpretes y binarios que no lo requieran (<code>chmod -s /usr/bin/python2.7</code>); realizar auditorías periódicas de binarios SUID/SGID del sistema como parte del proceso de <i>hardening</i> ; aplicar el principio de mínimo privilegio en la configuración de todo el software instalado.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	3	H-02, H-03, H-04
Alto	1	H-01
Medio	0	—
Bajo	0	—
Total	4	H-01, H-02, H-03, H-04

Lectura general

Tres de los cuatro hallazgos (75%) corresponden a **errores de configuración** más que a vulnerabilidades de software con CVE asociado: permisos excesivos sobre archivos sensibles, almacenamiento de credenciales en texto plano, y un binario con privilegios elevados innecesarios. Esto confirma un patrón frecuente en la industria: la configuración insegura suele representar un riesgo mayor y más fácil de explotar que las vulnerabilidades de día cero.

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. **(Prioridad crítica)** Eliminar inmediatamente cualquier archivo de backup o configuración que contenga credenciales en texto plano (H-02).
2. **(Prioridad crítica)** Reemplazar la lista negra de extensiones en formularios de carga por una lista blanca estricta, combinada con validación real del tipo de archivo (H-03).
3. **(Prioridad crítica)** Auditar y eliminar bits SUID innecesarios en binarios del sistema, en particular intérpretes de propósito general (H-04).
4. **(Prioridad alta)** Restringir permisos de claves privadas SSH a 600 y rotar toda clave que haya estado expuesta (H-01).
5. Actualizar los servicios desactualizados detectados durante el escaneo (Apache 2.4.41, kernel Linux 5.15.0-139) a sus últimas versiones estables soportadas.
6. Exigir autenticación en todo panel administrativo expuesto a la red.

Recomendaciones administrativas (políticas y procesos)

1. Establecer una política formal de gestión de credenciales que prohíba explícitamente su almacenamiento en texto plano, con rotación periódica obligatoria.
2. Incorporar capacitación para el equipo de desarrollo sobre validación segura de cargas de archivos (OWASP Top 10, categorías A04 y A05).
3. Definir un proceso trimestral de revisión de permisos de archivos y binarios SUID/SGID (*hardening checklist*).
4. Implementar un proceso formal de gestión de vulnerabilidades, con ventanas de parcheo definidas según criticidad.

6. Protocolo de Contingencia

Escenario de falla

Durante una prueba de carga de archivos sobre un formulario de subida como el identificado en H-03, un archivo malformado o un intento de explotación mal calibrado podría provocar un error fatal no controlado en el proceso de Apache/PHP, interrumpiendo la disponibilidad del servicio web de cara al cliente mientras dure la caída.

Impacto sobre la continuidad del negocio

Se vería afectado el servicio web público de INSECUR S.A., impidiendo el acceso de clientes y empleados a los sistemas alojados en el servidor comprometido. Según la duración de la interrupción y la existencia (o no) de redundancia, el impacto podría oscilar entre 15 minutos de indisponibilidad parcial y varias horas de caída total si no existe un servidor espejo disponible.

Plan de respuesta

1. **Activación:** un sistema de monitoreo activo (*healthchecks* HTTP periódicos) detecta la caída del servicio o códigos de error 5xx sostenidos y dispara una alerta automática al equipo de guardia.
2. **Contención:** en los primeros 15 minutos se aísla el servidor afectado de la red (regla de firewall o apagado de la interfaz), se detiene el proceso comprometido de Apache/PHP y se preservan los logs para análisis forense posterior.
3. **Recuperación:** se restaura el servicio desde un servidor espejo (*failover*) si existe, o se reinstala desde una imagen limpia versionada (Infraestructura como Código) reaplicando la configuración conocida y los últimos backups válidos.
4. **Comunicación:** se notifica de inmediato a la dirección de INSECUR S.A.; si se confirma una brecha con exposición de datos, se evalúa la notificación a clientes afectados y, de corresponder, a las autoridades competentes según la normativa de protección de datos vigente.
5. **Post-mortem:** se documenta la causa raíz, la línea de tiempo completa del incidente y las acciones tomadas; se actualizan los *runbooks* internos y las reglas de monitoreo para prevenir recurrencias.

RTO y RPO estimados

RTO (Recovery Time Objective): 2 horas, considerando la restauración desde servidor espejo o imagen versionada.

RPO (Recovery Point Objective): 1 hora, asumiendo una frecuencia de backups horaria para los componentes críticos.

7. Anexos

Anexo A — Bitácora de comandos

Se adjuntan en la carpeta `bitacora/` del branch `concatti-lucrecia` los siguientes archivos, uno por sesión de trabajo:

- `bitacora/clase_sala2_basic_pentesting_*.txt` — Sala Basic Pentesting.
- `bitacora/clase_sala3_rootme_20261005.txt` — Sala RootMe (sala de elección).

Las credenciales en texto plano fueron redactadas manualmente en ambos archivos previo a su entrega.

Anexo B — Capturas de pantalla

Las evidencias se encuentran en la carpeta `evidencias/` del branch, organizadas en subcarpetas por fase: `reconocimiento/`, `escaneo/`, `explotacion/` y `post/`. Cada archivo sigue la convención `<fase>.<ID>.png`, donde `<ID>` identifica la sala y el paso correspondiente (por ejemplo, `RM-08` para el paso 8 de la sala RootMe).

Anexo C — Hashes de credenciales obtenidas

```

1 # Formato: hallazgo_id  descripcion  sha256_hash
2 H-01  passphrase clave SSH (key)  873504
   f0103a88d762191a358f4aa432dbbcf8af64f19dd913d7f8f925191a0
3 H-02  password sudo (key)  3
   ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf5
4 ---  password SSH inicial (jan)  9
   eb6835cc95b053818b660bd9fc9f092a0b30cef89c1f0f17f469d5caa0ae61

```

Flags obtenidas (sala RootMe): siguiendo el control de *hash de las flags* de la cátedra, se incluye el hash SHA-256 de cada flag en lugar de su texto plano, evitando exponer valores que circulan en writeups públicos:

```

1 # Formato: flag  sha256_hash
2 user.txt  8
   c8b99b3c6b7a61eb0399dfab5b59c08126f998305c6d05fa44e0cc76cfad5b0
3 root.txt
   ec3faf2a7f12f82b7ab07a19ca777232b3f67ba2c2160e43802ee102a6a9a85c

```

Anexo D — Declaración ética firmada

Declaro que todas las actividades descriptas en este informe se realizaron dentro del alcance autorizado, en entornos controlados (laboratorios de TryHackMe) y con fines exclusivamente académicos, en el marco de la Actividad A08 de la cátedra Seguridad Aplicada a Sistemas de Información.

Lucrecia Concatti

05/10/2026

Firma del estudiante

Fecha